

Serious Criticism of the Agency for Digitization for Insufficient Security with MitID

Date: 23-06-2023

Decision

Public Authorities

Serious Criticism

Reported Breach of Personal Data Security

Supervision / Self-initiated Case

Processing Security

Unauthorized Access

Risk Assessment and Impact Analysis

The Data Protection Agency expresses serious criticism of both the Agency for Digitization and the Signature Group in a case where both parties shared responsibility for insufficient security related to login with MitID.

Journal Number: 2022-432-0079

Summary

In January 2022, several citizens experienced that when logging into their online banking via MitID, they gained access to other citizens' accounts. This was reported to the Data Protection Agency as a breach of personal data security by three financial institutions. This prompted the Data Protection Agency to initiate a case on its own accord to investigate the underlying problem.

The error turned out to be due to login requests to the same online bank, which in special cases could result in MitID issuing a so-called token to another session within milliseconds. This error could have been avoided if the broker (the company that facilitates the authentication response - in this case, the Signature Group) had validated citizens' logins with a technology called Broker Security Context. The Agency for Digitization, which is the data controller for MitID, had recommended this but did not make it a requirement.

However, the Data Protection Agency assesses in the decision that it should have been a requirement - and concludes that the Agency for Digitization has not had sufficient measures to achieve a security level that corresponds to the risks faced by citizens. At the same time, it is the Data Protection Agency's view that the Signature Group, as the data controller for the broker solution, also has not had appropriate security measures, as they used Broker Security Context in a manner different from that described in the recommendation.

On this basis, the Data Protection Agency expresses serious criticism of both the Agency for Digitization (below) and the Signature Group.

Decision

On January 6, 2022, the Data Protection Agency received reports from three financial institutions regarding similar breaches of personal data security.

The reports indicate that the financial institutions were informed by their data processor BEC that a number of customers had gained access to other customers' accounts when customers logged into their online banking with MitID. The reports further indicate that BEC has stated that there is a concurrency error regarding the token issued by MitID in connection with customers' access to the online banks.

On January 14, 2022, the Data Protection Agency requested further information about the incident from the Agency for Digitization, including answers to a number of questions. The Agency for Digitization submitted additional information to the Data Protection Agency on February 10, 2022.

On April 25, 2022, the Data Protection Agency sent a request for further information to the Agency for Digitization. On May 30, 2022, the Agency for Digitization provided such additional information.

1. Decision

After reviewing the case, the Data Protection Agency finds grounds to express serious criticism that the Agency for Digitization's processing of personal data has not been conducted in accordance with the rules in the General Data Protection Regulation [1] Article 32, paragraph 1.

Below follows a detailed review of the case and a justification for the Data Protection Agency's

decision.

It is noted that the agency has also today made a decision regarding the Signature Group. The Data Protection Agency found grounds to express serious criticism that the Signature Group's processing of personal data was not conducted in accordance with the rules in the General Data Protection Regulation Article 32, paragraph 1, as the Data Protection Agency found that the Signature Group had not implemented a security measure recommended by MitID in NeB Broker with sufficiently high entropy. It is the Data Protection Agency's view that the requirement under Article 32 for appropriate security will normally imply that as a data controller and broker to a technical login solution, where personal data is processed, here MitID, one ensures the correct implementation of recommended security measures to avoid unauthorized access to personal data. The Data Protection Agency finds that there is an aggravated risk profile when the login solution provides access to an online banking solution.

2. Case Presentation

It appears from the case that MitID is a digital identity solution and a replacement for NemID. The MitID solution is owned in a joint partnership between the financial sector (FR1) and the public sector (Agency for Digitization). FR1 and the Agency for Digitization have jointly established a common operational organization called MitID DFO consisting of employees from both the public sector (Agency for Digitization) and the financial sector (e-nettet). E-nettet represents the financial sector as the common IT development and operations company of the financial sector and is owned by all banks and mortgage credit institutions in Denmark. It further appears that the Agency for Digitization is the data controller for the processing of personal data in MitID.

The Agency for Digitization has stated that for a service provider to receive authentications from MitID, the service provider must have entered into an agreement.

with a broker. When the MitID core has verified that the user wishing to log in to a service is who they claim to be, an authentication response is generated, containing information such as name, date of birth, and risk data. The authentication response is sent to the broker for the service provider whose service the user wishes to access. The broker becomes independently responsible for the data received in the response. The broker forwards the received response to its service provider, possibly enriched with data that the broker itself possesses. Upon receiving the authentication response, the service provider becomes independently responsible for the received data. It is the broker that has the technical connection to the MitID solution. The service providers in this case are the three banks, which are thus independently responsible for data when they receive the authentication response from their broker and allow access to their respective online banking services. It is on this basis that the three banks have made reports to the Data Protection Authority.

According to the Agency for Digitization, MitID DFO became aware of the incident on January 3, 2022, where a bank customer gained access to another bank customer's online banking on January 3, 2022, due to the issuance of two identical JWT tokens. MitID DFO immediately followed up with the provider Nets, and a hotfix was initiated, which was implemented that same evening, resolving the issue. The following day, MitID DFO was informed that three additional incidents had been found where a bank customer had unlawfully gained access to another bank customer's online banking. MitID DFO then followed up again with Nets, and on January 10, 2022, an update of the description regarding the implementation and validation of MitID authentication, which brokers perform on behalf of service providers, was issued. In the update, validation of the context surrounding the returned JWT token was made mandatory, whereas this validation had previously only been a recommendation for brokers.

The Agency for Digitization has stated regarding the cause of the error that a flaw in the MitID core, which generates a JWT token in response to a login request, had a race condition, where the token in extraordinary cases was generated based on data related to another session if the login requests to the same online bank hit the same microservice/pod in the MitID infrastructure within a few milliseconds. A JWT token filled with data related to another session could thus be returned to the MitID broker. For brokers, it has been a recommendation that they should perform validation of the JWT tokens received from the MitID core (Broker Security Context). However, according to the Agency

for Digitization, the validation has been a recommendation and not a strict requirement. BEC and Nets themselves had not performed the validation. BEC uses Signaturgruppen as an eID broker, and Signaturgruppen is owned by Nets and is Nets' own eID broker.

After the incident, on January 10, 2022, material was sent to the brokers with information that it is now a requirement for brokers to implement and perform validation based on the Broker Security Context, along with guidance on how this is to be done. Additionally, a requirement was introduced for the use of high-entropy Broker Security Contexts. The requirement for mandatory implementation of the Broker Security Context with high entropy was identified and recommended by the provider as an additional measure to ensure that brokers can detect any errors in the underlying software from the MitID solution, for which the provider is not responsible, as well as any errors in the brokers' own implementations. The Agency for Digitization has stated that the agency chose to follow the provider's recommendation to make the requirement for the implementation of the Broker Security Context (with high entropy) mandatory for all brokers, after which a so-called security advisory was sent to all connected brokers.

According to the Agency for Digitization, the MitID core has undergone extensive testing processes covering, among other things, load/performance/stress tests, but these testing processes did not explicitly validate the returned JWT tokens to a sufficient extent, which has now been rectified.

3. Justification for the Data Protection Authority's decision

The Data Protection Authority bases its conclusion on the information in the case that the Agency for Digitization, as the data controller for MitID, provides brokers with guidelines on how to implement services in relation to MitID. It is further established that the Agency for Digitization had not made the use of the Broker Security Context mandatory but only recommended it.

3.1. Article 32 of the General Data Protection Regulation

It follows from Article 32, paragraph 1, of the General Data Protection Regulation that the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data.

Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects against these risks.

It is the Data Protection Authority's view that the requirement under Article 32 for appropriate security will normally imply that as a data controller for a technical login solution, here MitID, which providers must integrate with, ensures that the necessary instructions for implementing measures aimed at the secure use of the solution are communicated to the respective providers and reflect the risk scenarios associated with the processing.

Furthermore, it is the Data Protection Authority's view that there is a significant risk to the rights of data subjects when the solution is used at a national level as an authentication service for a large number of personal data about the data subject, and allows access to perform transactions with legal effect and... for unambiguous and irrefutable identification in a multitude of systems.

The Data Protection Agency finds on this basis that the Agency for Digitization – by not making the validation of the Broker Security Context mandatory for brokers until after January 10, 2022 – has not taken appropriate organizational and technical measures to ensure a level of security that is commensurate with the risks associated with the Agency for Digitization's processing of personal data, cf. Article 32, paragraph 1 of the General Data Protection Regulation.

After a review of the case, the Data Protection Agency finds that there is grounds for expressing serious criticism of the fact that the Agency for Digitization's processing of personal data has not occurred in accordance with the rules in Article 32, paragraph 1 of the General Data Protection Regulation.

In choosing a response, the Data Protection Agency has emphasized that the violation has resulted in unauthorized access to personal data, at least concerning financial matters, and that this access has likely posed a significant risk to the rights or freedoms of the data subjects. The Agency has further

emphasized that this concerns a nationwide solution, whose primary purpose is to validate the identification of individuals in order to provide access only to the information that they are entitled to access, including personal data, and which is used as a digital ID for a range of central private and public self-service solutions, etc.

Additionally, the Data Protection Agency has given weight to the fact that the Agency for Digitization has implemented the security measures in the Broker Security Context after the incident, which prevent identical tokens from granting unauthorized access to services, making them mandatory for all brokers.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).